

Question 1: The Mysterious 401 Error

Scenario: User reports "can't login to App X" (federated via Okta SAML). Okta logs show successful authentication. App X logs show 401 Unauthorized. Okta SAML assertion includes `groups` attribute with 50 groups. App X expects `groups` attribute. What's wrong?

Tutorial answer: "SAML assertion not signed correctly?"

Production answer:

- **HTTP header size limit.** 50 groups in SAML assertion creates 12 KB SAML response. Browser sends SAML response as POST body (okay). App X backend validates SAML, extracts groups, writes to session cookie. Cookie exceeds 4 KB browser limit. Cookie truncated. Next request has partial cookie → 401.
- **Fix:** Don't send all 50 groups. Send group IDs (compact) or use group claim (reference). Or switch to OIDC (groups in userinfo endpoint, not in token).
- **Why this matters:** This failure is invisible in Okta logs (authentication succeeded). Only visible at app layer (authorization failed). Requires understanding HTTP/cookie mechanics, not just SAML spec.

Question 2: The Privilege Escalation That Wasn't

Scenario: Security team reports "potential privilege escalation." User A (regular user) was seen with temporary `Global Administrator` role in Azure AD audit logs for 3 seconds, then reverted. User A claims they never requested this. Is this a breach?

Tutorial answer: "Yes, investigate for compromised account."

Production answer:

- **Privileged Identity Management (PIM) evaluation race.** User A requested `User Administrator` role (legitimate). PIM approval workflow granted it. But Azure AD's just-in-time activation has eventual consistency. For 3 seconds during activation, RBAC system saw user in "activating" state, which temporarily grants higher role for safety. Immediately downgraded to requested role after propagation.
- **Not a breach, not a bug:** This is expected behavior in PIM. Alternative would be "deny all actions during activation" (worse UX).
- **Why this matters:** Understanding distributed systems behavior (eventual consistency) in IAM context. Distinguishes between anomaly and attack.

Question 3: The Token That Shouldn't Work But Does

Scenario: AWS Lambda function uses IAM role. Role has policy: `"Effect": "Allow", "Action": "s3:GetObject", "Resource": "arn:aws:s3:::my-bucket/*", "Condition": {"IpAddress": {"aws:SourceIp": "203.0.113.0/24"}}`. Lambda deployed in VPC with NAT Gateway (IP 203.0.113.5). Lambda can read S3 objects (expected). Lambda moved to different VPC with NAT Gateway (IP 198.51.100.5). Lambda *still* reads S3 objects (unexpected). Why?

Tutorial answer: "Policy is cached?"

Production answer:

- **VPC Endpoint for S3.** Lambda in new VPC uses VPC Endpoint (not NAT Gateway). VPC Endpoint traffic uses AWS internal network, not public internet. `aws:SourceIp` condition **does not apply** to VPC Endpoint traffic (AWS docs: "Source IP is an AWS internal IP").
- **Security implication:** IP-based conditions are ineffective for VPC Endpoint traffic. Should use `aws:SourceVpce` condition instead.
- **Why this matters:** Workload identity (IAM role) + network architecture (VPC Endpoint) interaction. Most engineers don't test negative cases.

Question 4: The Federation Loop That Only Happens in Production

Scenario: Enterprise uses Okta (primary IdP) and Azure AD (secondary IdP for Office 365). Some apps federate to Okta, some to Azure AD. Configure "seamless SSO" - if user has Okta session, auto-login to Azure AD apps. Works in dev/staging. In production, 10% of users enter infinite loop: Okta → Azure AD → Okta → timeout. Why only in production? Why only 10% of users?

Tutorial answer: "Misconfigured federation metadata?"

Production answer:

- **Conditional Access policy interaction.** In production (not staging), Azure AD has Conditional Access policy: "require MFA for external network." 90% of users are on corporate network (trusted IP). 10% of users are remote (external network).
- **For 90%:** User hits Azure AD app → redirect to Okta (federation) → Okta session valid → redirect back to Azure AD with SAML assertion → Azure AD accepts (trusted IP, no MFA needed).
- **For 10%:** User hits Azure AD app → redirect to Okta → Okta session valid → redirect back to Azure AD with SAML assertion → Azure AD triggers MFA (external network) → redirects to Okta for MFA → Okta redirects to Azure AD (thinks auth complete) → Azure AD sees no MFA, redirects back to Okta → loop.

- **Why:** Conditional Access evaluated *after* federation. Okta doesn't know Azure AD needs MFA. Loop because neither IdP realizes the other can't satisfy the requirement.
- **Fix:** Use SAML `AuthnContextClassRef` to signal MFA requirement from Azure AD to Okta. Or disable Conditional Access policy for federated users (different risk tradeoff).
- **Why this matters:** Conditional Access policies are data-plane runtime logic. Federation is control-plane configuration. They interact in non-obvious ways that only surface under specific conditions (network location).

Question 5: Design Challenge - Zero Trust for Acquired Company

Scenario: You're hired as IAM architect at MegaCorp (100k employees). Just acquired StartupCo (5k employees). Leadership wants "zero trust architecture" for StartupCo users accessing MegaCorp resources. Constraints: StartupCo keeps their Google Workspace (political reasons). Must complete in 6 months. \$500k budget. Design the architecture.

What hiring managers look for:

Red flags:

- "Migrate everything to Azure AD" (ignores political constraint)
- "Just federate Google → Azure" (no zero trust principles)
- Focuses on products, not principles

Green flags:

- Defines "zero trust" specifically: verify explicitly (identity + device), least privilege, assume breach
- Acknowledges tradeoffs: perfect zero trust impossible in 6 months, must prioritize
- Proposes phased approach

Genius-level answer:

Phase 1 (Months 1-2): Identity Federation + Device Trust Foundation

- Deploy Okta as federation broker: Google Workspace ← Okta → Azure AD
- StartupCo users login with Google, but Okta enforces:
- Device registration (Jamf for Mac, Intune for Windows)
- MFA (Okta Verify, FIDO2)
- Context-aware policies (location, device compliance)
- Azure AD B2B guests for StartupCo users (limited by default)

Phase 2 (Months 3-4): Least Privilege + App Segmentation

- Map MegaCorp resources to sensitivity tiers:
- Tier 0: Public (allow all)
- Tier 1: Internal (require device compliance)
- Tier 2: Confidential (require device compliance + MFA + app approval)
- Tier 3: Restricted (no StartupCo access)
- Azure AD Conditional Access policies per tier
- StartupCo users start at Tier 0, elevate per business need

Phase 3 (Months 5-6): Assume Breach + Monitoring

- Deploy Azure AD Identity Protection (anomaly detection)
- UEBA for StartupCo users (Microsoft Sentinel or Splunk)
- Continuous access evaluation: short-lived tokens (15 min), revocation events
- Incident response runbook: "If StartupCo user compromised, how do we contain?"

Cost breakdown:

- Okta: \$150k/year (5k users × \$30/user)
- Jamf: \$50k/year (device management)
- Azure AD P2: \$200k/year (5k users × \$40/user for Conditional Access + Identity Protection)
- Implementation: \$100k (consulting)
- Total: \$500k first year

Tradeoffs explicitly acknowledged:

- Not "true" zero trust (no network segmentation, no micro-segmentation)
- StartupCo device trust depends on Jamf enforcement (can be bypassed by sophisticated attacker)
- Google Workspace admin still god-mode (business accepted this risk)
- No integration with MegaCorp's on-prem AD (StartupCo stays cloud-only)

Why this answer works:

- Demonstrates understanding of identity (federation), device trust (Jamf/Intune), policy (Conditional Access), monitoring (Identity Protection)
- Phased approach acknowledges timeline constraint
- Cost breakdown shows budget awareness
- Tradeoffs section shows maturity ("zero trust is a spectrum, not binary")

Final Calibration: Can You Operate or Just Configure?

You can operate if you can answer:

- "Design the monitoring dashboard for your IdP that predicts outages before users notice."
- "Walk me through debugging a SAML assertion failure where Okta logs say success, AWS Console logs say auth error, and CloudTrail shows no event."
- "Calculate the blast radius if your Azure AD global admin account is compromised. How long to detect, contain, recover?"
- "Pitch the CFO on spending \$2M to migrate from ADFS to Azure AD. What's the business case?"

You only configured if your answers:

- Cite vendor docs instead of production experience
- Lack failure stories ("we set up Okta and it just worked")
- Focus on features instead of tradeoffs
- Don't mention operational cost, toil, or technical debt

The bar is: **Have you been paged at 2am for an IAM outage and restored service?** If not, you're not yet staff-level.